SOMAIYA VIDYAVIHAR UNIVERSITY
K J Somaiya School of Engineering
(formerly K J Somaiya College of Engineering)

OWASP ZAP (Web Application Vulnerability Scanner)

Somaiya TRUST

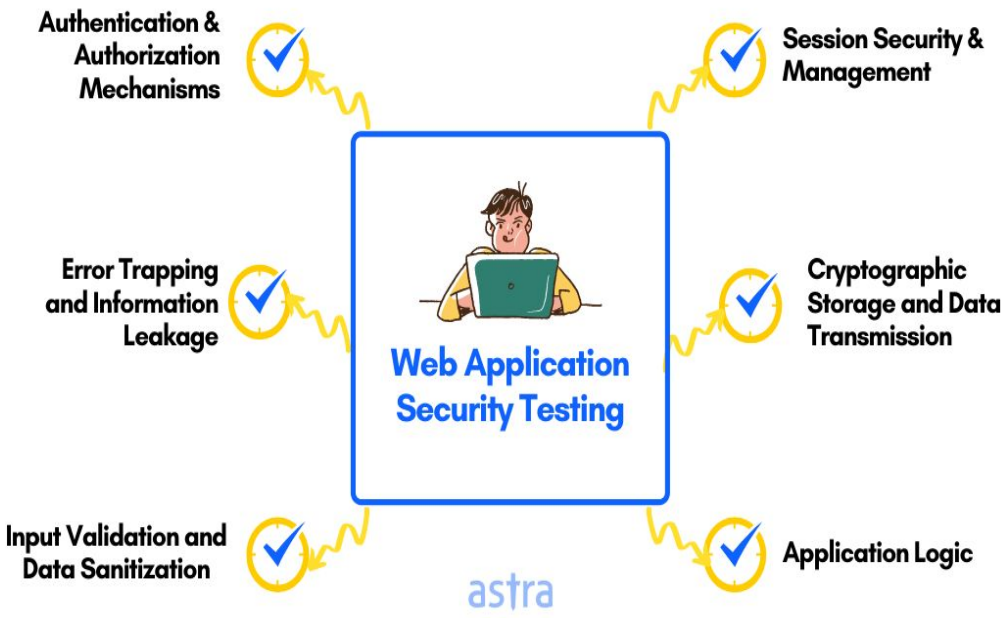
Name of Presenter: Sahil Kanchan 16010123290
Shlok Gawade 16010123315
Shoumik Trivedi 16010123317

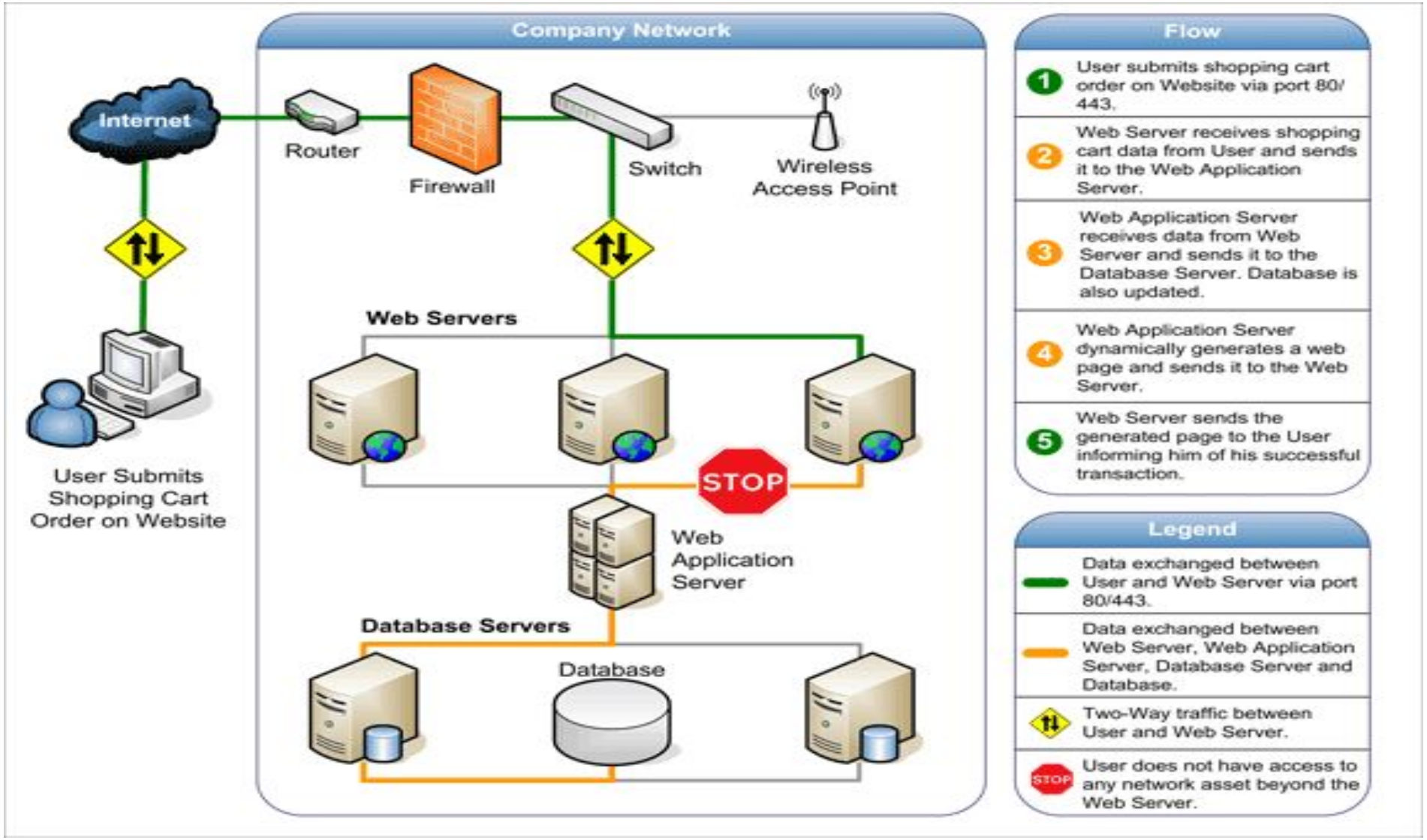
Introduction to Web Security

- Web applications are widely used for banking, shopping, and education.
- These applications may contain **security vulnerabilities**.
- Attackers exploit these vulnerabilities to steal data or damage systems.
- Therefore, **web application security testing tools** are required.

Examples of vulnerabilities:

- SQL Injection
- Cross-Site Scripting (XSS)
- Broken Authentication
- Security Misconfiguration




Company Network
Internet
Router
Firewall
Switch
Wireless Access Point
Web Servers
STOP
Web Application Server
Database Servers
Database
User Submits Shopping Cart Order on Website
Flow
1 User submits shopping cart order on Website via port 80/443.
2 Web Server receives shopping cart data from User and sends it to the Web Application Server.
3 Web Application Server receives data from Web Server and sends it to the Database Server. Database is also updated.
4 Web Application Server dynamically generates a web page and sends it to the Web Server.
5 Web Server sends the generated page to the User informing him of his successful transaction.
Legend
Data exchanged between User and Web Server via port 80/443.
Data exchanged between Web Server, Web Application Server, Database Server and Database.
Two-Way traffic between User and Web Server.
STOP
User does not have access to any network asset beyond the Web Server.

What is OWASP?

- OWASP stands for **Open Web Application Security Project**.
- It is a **non-profit organization** focused on improving software security.
- OWASP provides tools, documentation, and security standards.

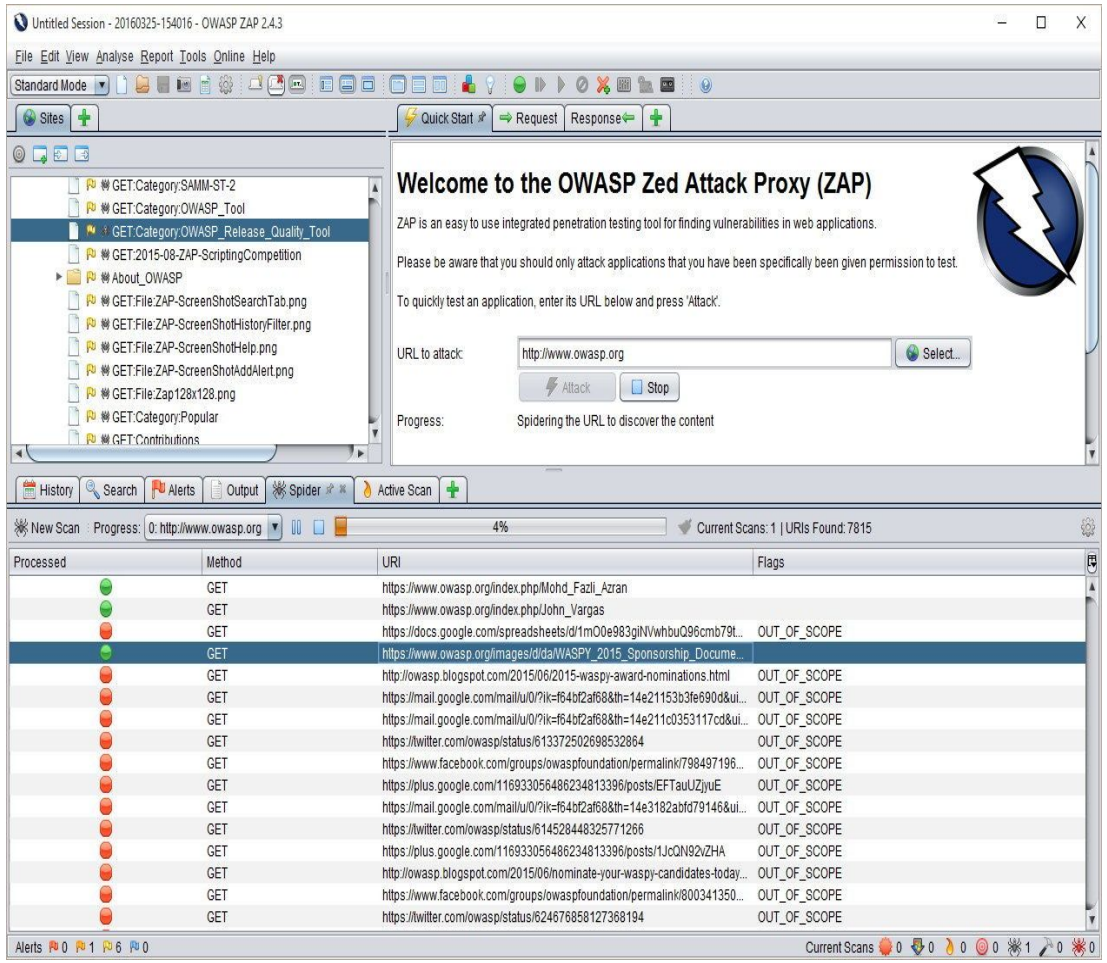
Popular OWASP Projects:

- OWASP Top 10
- OWASP ZAP
- OWASP Juice Shop
- OWASP Dependency Check

OWASP™

What is OWASP ZAP?

- **OWASP ZAP (Zed Attack Proxy)** is an **open-source web application vulnerability scanner**.
- It is used to **identify security vulnerabilities in web applications**.
- Works as a **proxy between the browser and the web server**.
- Widely used by **developers, testers, and security professionals**.



Main purpose:

- Detect security weaknesses
- Improve application security
- Perform penetration testing

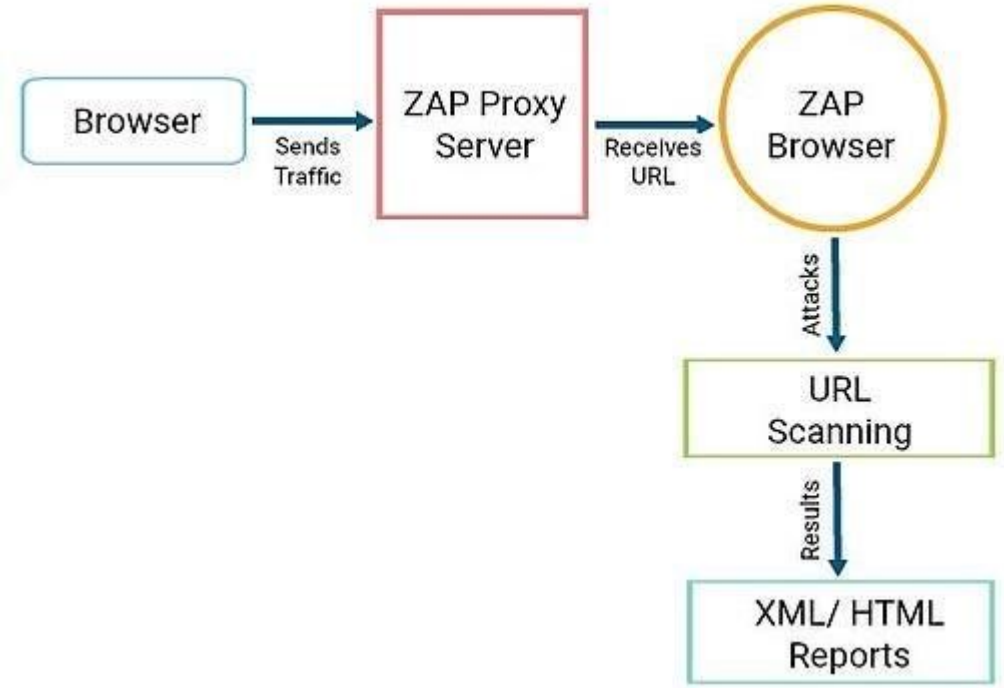
Features of OWASP ZAP

- Automated vulnerability scanning to detect security issues in web applications.
- Passive scanning to analyze traffic without sending attacks.
- Active scanning to test applications by sending attack requests.
- Spider (website crawler) to automatically discover web pages.
- Intercepting proxy to monitor and modify browser–server requests.
- Authentication testing for secured web applications.
- API security testing for REST and other web APIs.
- Add-ons and extensions to extend functionality.

How OWASP ZAP Works

Working process:

1. User enters the **website URL**.
2. ZAP **spiders the website** and finds all pages.
3. Passive scan analyzes traffic for vulnerabilities.
4. Active scan sends attack payloads.
5. ZAP generates a **vulnerability report**.



Result: vulnerabilities categorized as

- High
- Medium
- Low
- Informational

Architecture of OWASP ZAP

1. Proxy Server: The proxy server intercepts and monitors the requests and responses between the browser and the web application.

2. Spider: The spider automatically crawls the website to discover all available pages and links.

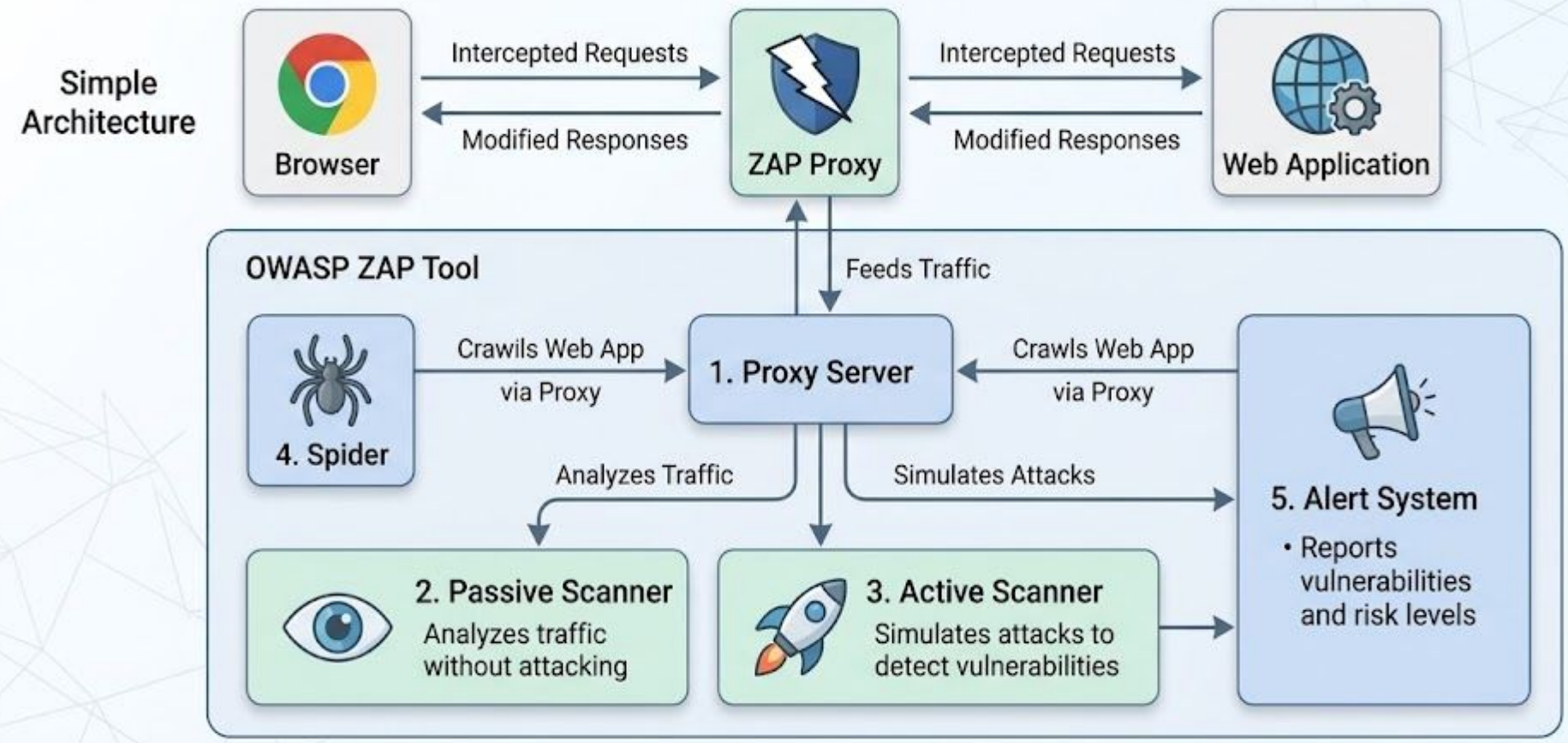
3. Passive Scanner: The passive scanner analyzes the web traffic for potential vulnerabilities without sending attack requests.

4. Active Scanner: The active scanner simulates attacks on the web application to identify security vulnerabilities.

5. Alert System: The alert system reports detected vulnerabilities and classifies them based on risk levels.

Simple Architecture:
The communication flow works as Browser → ZAP Proxy → Web Application.

Main Components and Flow



Demo

Demo steps:

1. Open **OWASP ZAP**
2. Enter website URL
3. Run **Automated Scan**
4. ZAP crawls the website
5. Tool generates **vulnerability report**

Advantages

Advantages of OWASP ZAP:

- Free and open source
- Easy to use interface
- Automated scanning
- Supports beginners and professionals
- Large community support
- Regular updates and plugins

Limitations

- **False Positives**:

  OWASP ZAP may sometimes report vulnerabilities that are not actual security issues, so results need manual verification.

- **Complex Configuration**:

  For large or complex web applications, proper configuration is required to perform effective scanning.

- **Not a Complete Replacement:**

  OWASP ZAP cannot fully replace manual penetration testing done by security experts.

- **Human Analysis Needed:**

  Some advanced vulnerabilities require human understanding and analysis.

- **Time-Consuming Scans:**

  Full scans of large web applications may take a long time to complete.

- **Limited Business Logic Detection:**

  Some logical flaws in applications cannot be detected automatically by the tool

Conclusion

- Web application security is very important because many services like banking, shopping, and education depend on web applications. Protecting these applications helps prevent data theft, unauthorized access, and other cyber attacks.
- OWASP ZAP is a powerful open-source web application vulnerability scanner used to identify security weaknesses in websites.
- It helps detect vulnerabilities early, allowing developers and security testers to fix issues before attackers exploit them.
- OWASP ZAP is widely used by developers, testers, and cybersecurity professionals to improve the security and reliability of web applications.